

Class 10 Lateral Movement & Privilege Escalation

What is Lateral Movement?

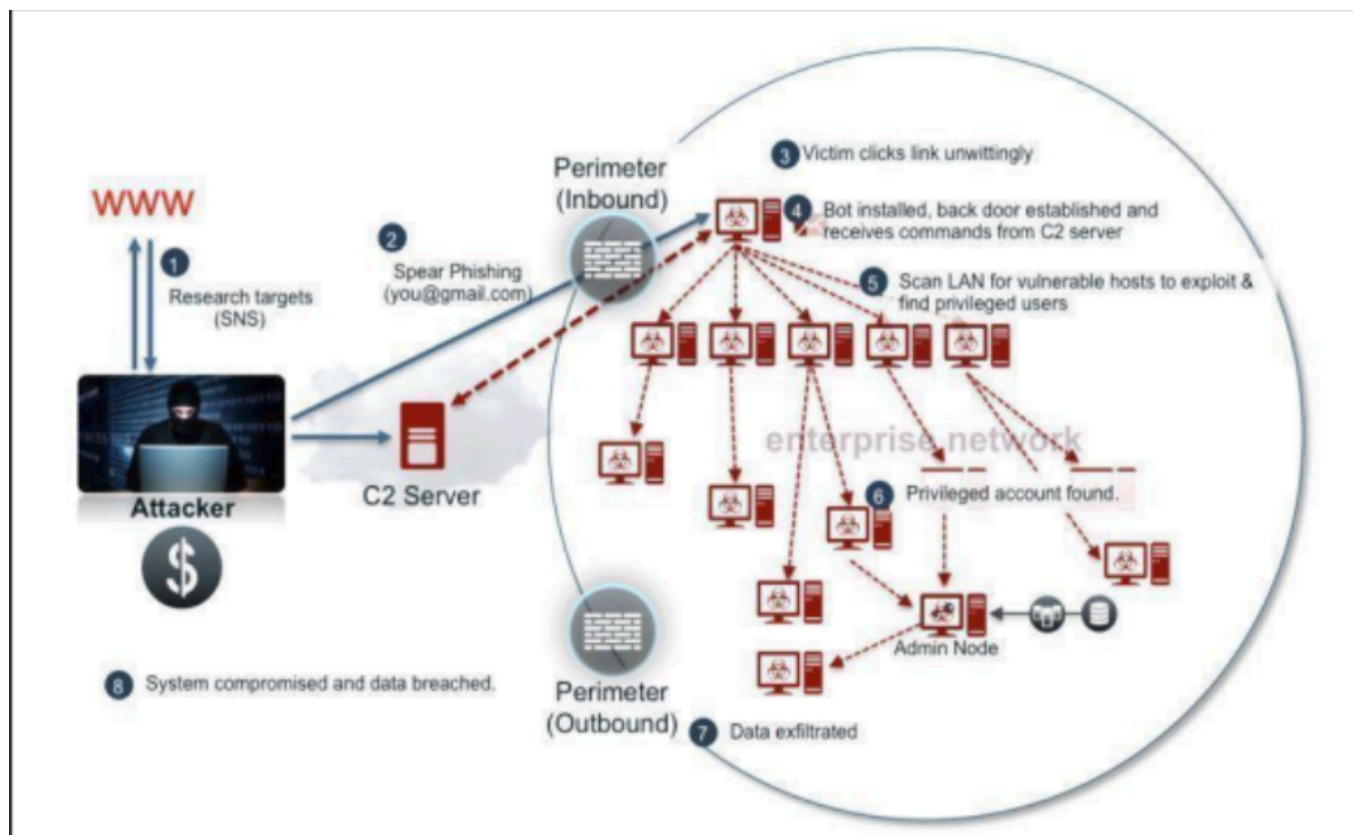
Lateral Movement means an attacker moves from one hacked computer to other computers inside the same network.

After gaining access to one system, the attacker spreads through the network to:

- Find important data
- Access powerful accounts
- Reach critical systems like domain controllers
- Spread malware or ransomware

Example attack path:

Phishing email → User computer hacked → Attacker moves to other systems → Gains domain controller access → Controls the whole network.



Why attackers perform Lateral Movement

Attackers perform **Lateral Movement** because the first computer they hack usually does not contain their real target.

Example:

- Attacker hacks an **employee laptop** first.
- The important targets are **file servers, domain controllers, or database servers**.
- So, the attacker moves through the network to reach those valuable systems.

Common Lateral Movement Techniques

Pass-the-Hash (PtH) – How it works

Pass-the-Hash is a technique where an attacker uses a stolen **password hash** to authenticate to another system **without knowing the actual password**.

How it works (step-by-step):

1. Initial compromise

- Attacker gains access to a computer (for example, through phishing or malware).

2. Steal password hashes

- The attacker extracts password hashes stored in the system's memory or credential storage.
- Tools like **Mimikatz** can be used to obtain these hashes.

3. Reuse the hash

- Instead of cracking the password, the attacker directly uses the stolen hash to authenticate to another machine.
- The system accepts the hash as proof of identity.

4. Move to other systems

- If the user account has access, the attacker can connect to file servers, admin systems, or domain controllers.

Example:

- Employee laptop is compromised.
- Attacker steals an administrator account hash.
- Attacker uses that hash to log into a server.

- Attacker gains higher access and continues moving through the network.

SOC Indicators:

- Unusual **NTLM authentication** activity.
- Login attempts without normal password entry.
- One account accessing many machines quickly.
- Unexpected administrator logins.

Pass-the-Ticket (Kerberos Attack) – How it works

Pass-the-Ticket is a technique where an attacker steals a valid **Kerberos authentication ticket** and uses it to access network resources without knowing the user's password.

How it works (step-by-step):

1. Initial compromise

- Attacker gains access to a user's computer.

2. Steal Kerberos tickets

- The attacker extracts Kerberos tickets stored in memory.
- These tickets are used by Windows networks for authentication.

3. Reuse the ticket

- The attacker injects the stolen ticket into their session.
- The network treats the attacker as the legitimate user.

4. Access other systems

- If the stolen ticket belongs to a privileged account, the attacker can access servers, admin systems, or sensitive data.

Example:

- Attacker compromises an employee machine.
- Steals a Kerberos ticket from memory.
- Uses the ticket to access a file server or domain resource.
- Moves deeper into the network.

SOC Indicators:

- Suspicious Kerberos ticket usage.
- Unusual **TGT (Ticket Granting Ticket)** activity.

- A user account accessing systems at unusual times or locations.
- Unexpected privileged account authentication.

Remote Desktop Protocol (RDP) – How it works

RDP allows a user to remotely control another computer over a network. Attackers use it for **lateral movement** after stealing valid login credentials.

How it works (step-by-step):

1. Steal credentials

- Attacker obtains a username and password through phishing, malware, or other methods.

2. Connect using RDP

- The attacker uses RDP to connect to another machine inside the network.
- RDP commonly uses **Port 3389**.

3. Gain remote access

- If the credentials are valid, the attacker gets a desktop session on that system.

4. Move deeper into the network

- The attacker can access files, install malware, or use the system to attack other machines.

Example:

- Attacker steals an administrator password.
- Uses RDP on port **3389** to log into a server.
- Gains control and continues attacking the network.

SOC Indicators:

- Unexpected internal RDP connections.
- Logins from unusual locations or devices.
- RDP activity outside normal working hours.
- Multiple failed login attempts followed by a successful login.

SMB / Windows Admin Shares – How it works

SMB (Server Message Block) is a Windows network protocol used for sharing files and resources. Attackers use **Windows Admin Shares** to

move files and tools between computers inside a network.

How it works (step-by-step):

1. Gain access

- Attacker obtains valid credentials with administrative privileges.

2. Access admin shares

- The attacker connects to hidden Windows shares like:
 - `\\target\C$`
- This gives access to the target computer's C: drive remotely.

3. Copy tools or malware

- The attacker copies files, scripts, or hacking tools to the remote machine.

4. Execute and spread

- Using tools like **PsExec**, **Impacket**, or **CrackMapExec**, the attacker runs commands remotely and moves to more systems.

Example:

- Attacker compromises an admin account.
- Connects to `\\server\C$`.
- Copies a malicious tool to the server.
- Executes it and gains control of the system.

SOC Indicators:

- Unexpected access to admin shares.
- Suspicious file transfers between internal machines.
- New service creation events (common when tools like PsExec are used).
- Unusual administrative activity across multiple systems.

Windows Management Instrumentation (WMI) – How it works

WMI (Windows Management Instrumentation) is a Windows feature that allows administrators to manage computers remotely. Attackers abuse it to **execute commands on other systems** in a network.

How it works (step-by-step):

1. **Gain access**

- Attacker obtains valid credentials or admin privileges.

2. **Use WMI remotely**

- The attacker sends commands to another Windows machine using WMI.

3. **Execute processes**

- WMI creates or runs a process on the target system.
- Example:

```
wmic /node:target process call create "malware.exe"
```

4. **Continue the attack**

- The attacker can install malware, steal data, or move further across the network.

Example:

- Attacker compromises one computer.
- Uses WMI to run commands on another server.
- Gains access and continues lateral movement.

SOC Indicators:

- Unexpected WMI process creation.
- Remote WMI execution activity.
- Suspicious command-line usage.
- Unusual administrative actions from user accounts.

Real SOC Scenario – Brief Explanation

1. **Suspicious login** → Attacker gains access to a user laptop.
2. **Mimikatz executed** → Attacker steals admin credentials.
3. **Credentials dumped** → Attacker gets higher-level access.
4. **Logs into file server** → **This is Lateral Movement** because the attacker moves from the compromised laptop to another system in the network.
5. **Ransomware deployed** → Attacker damages or encrypts systems.

Lateral Movement = Moving from one compromised machine to another to reach valuable targets.

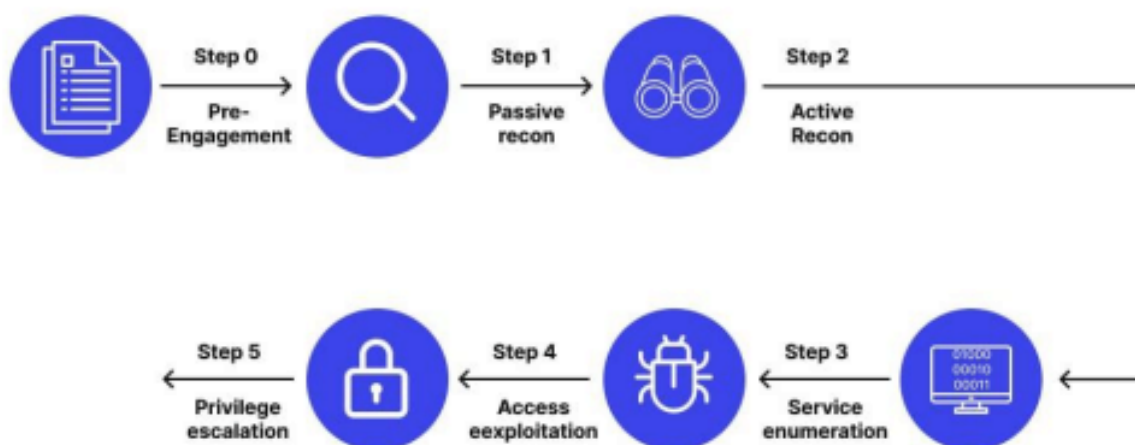
Privilege Escalation

Privilege Escalation is when an attacker increases their access level from a normal user to a more powerful account.

Example:

- Attacker gains a **normal user account**.
- Exploits a weakness or steals credentials.
- Gets **Administrator access**.

Goal: Gain higher permissions to access sensitive data, control systems, or perform further attacks.



Privilege Escalation Types – Brief Explanation

1. Vertical Privilege Escalation

- Attacker gains **higher-level permissions**.
- Moves from a lower privilege account to a powerful account.
- **Example:**
Normal User → Local Admin → Domain Admin

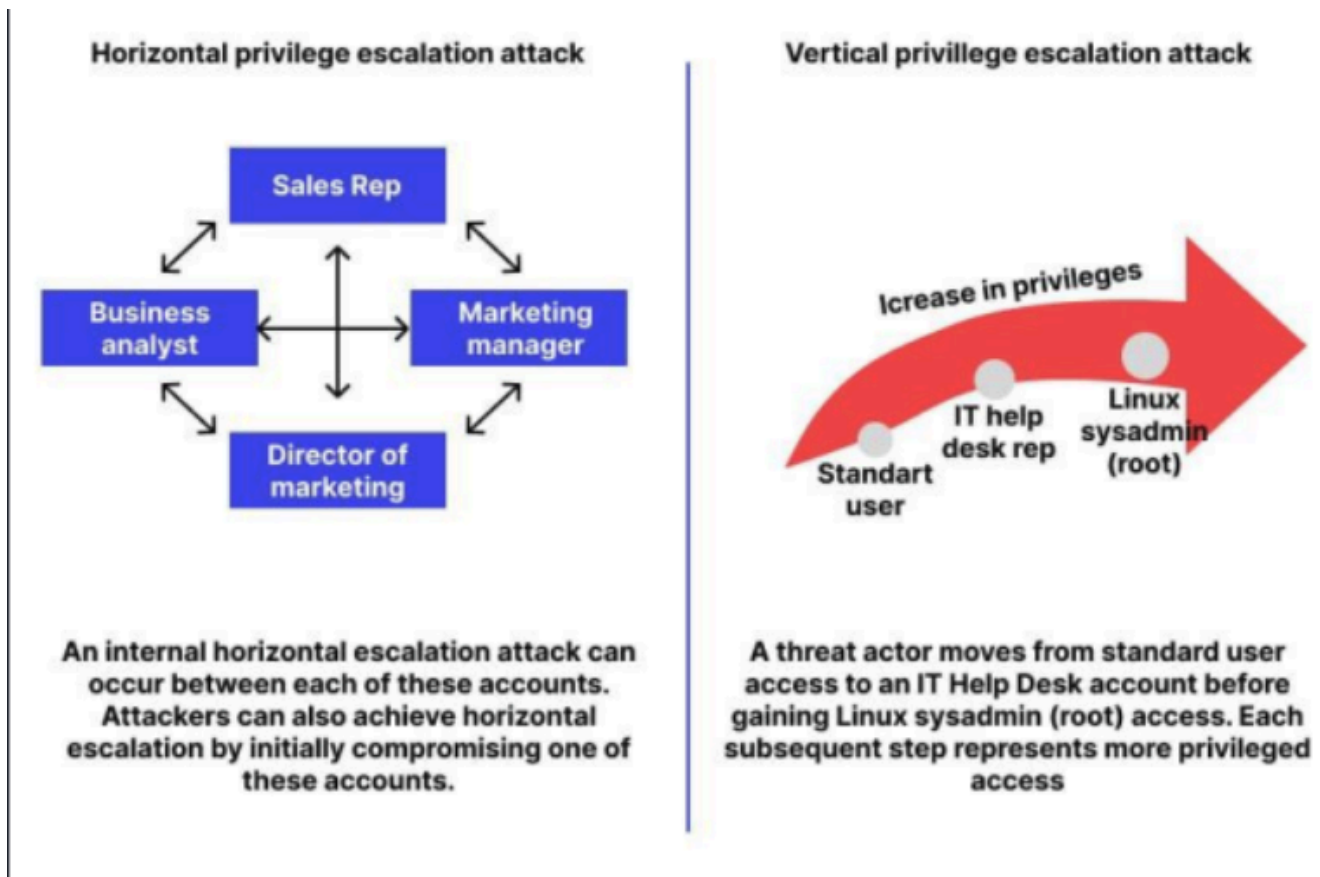
2. Horizontal Privilege Escalation

- Attacker accesses **another user's account with similar privilege level**.
- The access level is not higher, but the attacker gains access to another person's data or account.

- **Example:**
Employee Account → Manager Account

Simple difference:

- **Vertical** = Moving up (User → Admin)
- **Horizontal** = Moving sideways (User → Another User)



Why Attackers Need Privilege Escalation – Brief Explanation

Attackers often start with **low-level access** (like a normal user account), but they need **higher privileges** to gain full control.

They try to become:

- **Administrator**
- **Root user**
- **Domain Admin**

With higher privileges, attackers can:

- Disable security tools

- Access sensitive data
- Control more systems
- Install malware or ransomware

Simple idea:

Low privilege = Limited access

High privilege = More control over the system and network.

Common Privilege Escalation Techniques – How they work

1. Exploiting Software Vulnerabilities

How it works (step-by-step):

1. Find a weakness

- Attacker identifies a vulnerable software, outdated Windows component, or insecure driver.

2. Run an exploit

- Attacker uses a technique to abuse the vulnerability.

3. Gain higher privileges

- The exploit allows the attacker to move from a normal user account to **Administrator** access.

4. Take control

- With admin rights, the attacker can install malware, disable security tools, or access sensitive systems.

Example:

- User account → Exploits outdated Windows kernel → Administrator access

SOC Indicators:

- Suspicious exploitation activity.
- Unexpected privilege changes.
- Vulnerable software being abused.

2. Credential Dumping

How it works (step-by-step):

1. Access a system

- Attacker first compromises a computer with limited access.

2. Access credential storage

- Attacker targets areas like **LSASS memory**, where Windows stores authentication information.

3. Extract credentials

- Tools like **Mimikatz** can extract password hashes or credentials.

4. Use stolen credentials

- Attacker uses admin credentials to gain higher privileges or move to other systems.

Example:

- Compromised user laptop → Dump LSASS credentials → Obtain admin password → Administrator access

SOC Indicators:

- Unauthorized LSASS process access.
- Credential dumping alerts.
- Suspicious use of tools like Mimikatz.
- Unusual administrator logins.

3. Misconfigured Permissions

How it works (step-by-step):

1. Find weak permissions

- Attacker discovers a file, folder, or service that has incorrect permissions.

2. Identify a powerful service

- Example: A service runs with **SYSTEM** privileges but its executable file can be modified by a normal user.

3. Replace or modify the file

- Attacker replaces the legitimate file with a malicious one.

4. Gain higher privileges

- When the service runs again, it executes the attacker's file with SYSTEM privileges.

Example:

- Normal User → Modify SYSTEM service file → SYSTEM/Admin access

SOC Indicators:

- Unexpected changes to service files.
 - Unauthorized file modifications.
 - Suspicious services running with high privileges.
-

4. Token Impersonation

How it works (step-by-step):

1. Steal a high-privilege token

- Windows uses access tokens to identify user permissions.
- Attackers steal tokens from privileged processes.

2. Impersonate another user

- The attacker uses the stolen token to act as that user.

3. Access resources

- The attacker gains permissions of the impersonated account.

Example:

- Normal User → Steals Admin token → Impersonates Admin → Higher access

SOC Indicators:

- Suspicious token usage.
 - Unusual privileged process activity.
 - Unexpected admin actions from normal users.
-

5. Scheduled Task Abuse

How it works (step-by-step):

1. Find scheduled tasks

- Attackers look for tasks that run with administrator privileges.

2. Modify the task

- They change the task action to execute malicious commands or files.

3. Wait for execution

- When the scheduled task runs, it executes with admin privileges.

4. Gain elevated access

- The attacker receives higher-level permissions.

Example:

- User access → Modify admin scheduled task → Task runs → Admin access

SOC Indicators:

- New or modified scheduled tasks.
- Suspicious task execution.
- Unknown programs running with elevated privileges.

SOC Indicators of Privilege Escalation – Brief Explanation

SOC teams monitor these signs to detect attackers gaining higher privileges.

Common Indicators:

1. Sudden admin rights assignment

- A normal user suddenly receives Administrator privileges.
- May indicate unauthorized privilege escalation.

2. New admin account creation

- Attacker creates a new account with admin rights for persistence.

3. Service creation events

- Attackers create or modify services to run malicious programs with high privileges.

4. Suspicious LSASS access

- Attackers try to access LSASS memory to steal credentials.

5. Privilege escalation exploits

- Attempts to exploit vulnerabilities to gain higher permissions.

Important Windows Event IDs:

- **Event ID 4672** → Special privileges assigned to a user (possible admin activity)
- **Event ID 4688** → New process creation (shows programs being executed)
- **Event ID 4720** → New user account created
- **Event ID 4732** → User added to an administrator group

Simple idea:

SOC looks for unusual changes in **accounts, permissions, processes, and services** that indicate an attacker is trying to gain more control.

Real Ransomware Scenario (Attack Chain)

A **real ransomware attack** usually happens in multiple stages:

1. Phishing Email

- Attacker sends a fake email to trick a user into opening a malicious link or file.

2. User Laptop Compromise

- Malware infects the user's computer and gives the attacker initial access.

3. Credential Dumping

- Attacker steals usernames, passwords, or hashes from the compromised system.

4. Privilege Escalation

- Attacker gains higher permissions, such as Administrator or Domain Admin access.

5. Lateral Movement

- Attacker moves from the infected laptop to other systems in the network.

6. Domain Controller Access

- Attacker compromises the central system that controls user accounts and network resources.

7. Ransomware Deployment

- Attacker spreads ransomware across the network and encrypts data.

Simple flow:

Initial Access → Steal Credentials → Gain Higher Privileges → Move Across Network → Take Control → Deploy Ransomware.

Difference B/W Lateral Movement & Privilege Escalation

Feature	Lateral Movement	Privilege Escalation
Goal	Move across systems	Gain higher permissions
Direction	Sideways	Upwards
Example	Laptop -> Server	User -> Admin
Purpose	Expand Access	Gain Control

SOC L1 Thinking Task

Log sequence:

1. **User laptop executes Mimikatz**
 - Attacker is attempting **Credential Dumping**.
2. **LSASS memory accessed**
 - Attacker extracts credentials from Windows memory.
3. **Admin login occurs from that machine**
 - Stolen admin credentials are used.
 - This indicates **Privilege Escalation** because the attacker moved from a normal user account to admin-level access.
4. **RDP connection to file server**
 - Attacker is moving to another system.
 - This indicates **Lateral Movement**.

Identified Stages:

- ✅ **Credential Dumping** → Mimikatz + LSASS access
- ✅ **Privilege Escalation** → Admin credentials gained and used
- ✅ **Lateral Movement** → RDP connection to file server

Attack flow:

User Laptop → Credential Dumping → Privilege Escalation → Lateral Movement → File Server Access.

Answer Of Task

Step	Activity	Stage
1	Mimikatz executed	Credential Dumping
2	LSASS accessed	Credential Dumping
3	Admin login occurs	Privilege Escalation
4	RDP to file server	Lateral Movement

The Stages occurred are:

Credential Dumping -> Privilege Escalation -> Lateral Movement